

GESTIÓN DE INCIDENTES

BY NOVA TECH SOLUTIONS

PLAN DE RESPUESTA Y GESTIÓN DE INCIDENTES DE SEGURIDAD

Introducción

El presente documento tiene como objetivo primordial establecer el marco operativo y estratégico para la gestión de incidentes de seguridad de la información dentro de NovaTech Solutions. La capacidad de resiliencia de la organización en un entorno tecnológico dinámico no depende únicamente de sus controles preventivos, sino de su aptitud para reaccionar de manera coordinada ante eventos adversos. El presente plan busca minimizar el impacto operativo, financiero y reputacional, garantizando la continuidad de los servicios críticos y el cumplimiento de las obligaciones legales vigentes.

Estructura Organigrama del Equipo de Respuesta (CSIRT)

La eficacia de la respuesta ante incidentes en NovaTech no reside únicamente en la capacidad técnica, sino en la integración interdisciplinaria. Se establece una estructura jerárquica y colaborativa dividida en tres niveles de participación:

Miembros Permanentes (Núcleo de Decisión y Ejecución): Estos perfiles lideran la operación desde el minuto cero de cualquier detección:

- **Director del Incidente (CISO / Oficial de Seguridad):**
 - *Función:* Máxima autoridad en la crisis. Actúa como el puente entre la parte técnica y la Dirección General.
 - *Responsabilidades:* Declarar formalmente el inicio y fin del incidente, autorizar presupuestos de emergencia y validar las comunicaciones externas.
- **Coordinador Técnico de Infraestructura (Líder de TI):**
 - *Función:* Operaciones de Red y Sistemas. Es el responsable de la estabilidad de la plataforma.
 - *Responsabilidades:* Ejecutar cambios en la configuración de servidores, gestionar el tráfico en la nube y asegurar que las herramientas de defensa tengan visibilidad total.
- **Analista de Seguridad:**
 - *Función:* Actuar como la primera línea de defensa operativa y reactiva de la organización ante alertas confirmadas.
 - *Responsabilidades:* Monitorear de forma continua los sistemas de detección, validar la veracidad de las alertas de seguridad, ejecutar los protocolos de

contención inicial y documentar técnicamente cada evento detectado para el registro histórico de incidentes.

- **Líder de Custodia de Datos (Dueño del CRM / Base de Datos):**
 - *Función:* Garantizar la integridad de la información sensible.
 - *Responsabilidades:* Evaluar si hubo exfiltración de datos de clientes, coordinar con el equipo de TI para restaurar respaldos y verificar la consistencia de los datos recuperados.
- **Especialista en Caza de Amenazas (Threat Hunter):**
 - *Función:* Ejecutar una vigilancia proactiva y avanzada para identificar amenazas ocultas que no han disparado alertas automáticas.
 - *Responsabilidades:* Realizar búsquedas activas de indicadores de compromiso (IoC) en los sistemas, analizar patrones de comportamiento anómalos en la red y proponer ajustes preventivos a los sistemas de detección basados en nuevas tácticas de ataque identificadas.
- **Especialista en Análisis Forense Digital:**
 - *Función:* Realizar la investigación técnica detallada post-incidente para determinar el origen y alcance real de la brecha.
 - *Responsabilidades:* Recolectar y preservar evidencia digital de manera que mantenga su validez legal, reconstruir la línea del tiempo del ataque y emitir el informe técnico que identifique la causa raíz del incidente.

Miembros Adscritos (Apoyo Especializado según el Incidente): Estos integrantes se incorporan al CSIRT solo cuando el incidente afecta sus áreas de competencia:

- **Oficial de Cumplimiento Legal y Privacidad:**
 - *Cuando se convoca:* Siempre que exista una posible brecha de datos personales.
 - *Responsabilidad:* Evaluar las implicaciones legales y multas potenciales, y redactar las notificaciones oficiales a las autoridades regulatorias.
- **Director de Comunicación y Relaciones Públicas:**
 - *Cuando se convoca:* Cuando el incidente afecta la disponibilidad del SaaS para los clientes o hay riesgo de filtración pública.
 - *Responsabilidad:* Gestionar la reputación de la marca y redactar los comunicados oficiales para clientes y medios de comunicación, evitando el pánico informativo.
- **Gestor de Recursos Humanos:**
 - *Cuando se convoca:* En incidentes originados por amenazas internas o errores humanos graves de colaboradores.

- *Responsabilidad:* Asesorar sobre la aplicación del régimen de sanciones y manejar las implicaciones laborales de los empleados involucrados.
- **Enlace de Customer Success (Atención al Cliente):**
 - *Cuando se convoca:* En caídas críticas de sistemas que impidan el cumplimiento de los SLA (Acuerdos de Nivel de Servicio).
 - *Responsabilidad:* Mantener informados a los clientes clave sobre los tiempos estimados de recuperación, funcionando como un amortiguador de quejas.

Soporte Externo (Terceros Especializados): NovaTech reconoce que ciertos incidentes superan la capacidad interna:

- **Expertos en Informática Forense Externa:** Consultores contratados para realizar investigaciones profundas si se requiere presentar evidencia ante tribunales.
- **Proveedores de Infraestructura:** Enlace directo con los proveedores de nube para resolver fallas a nivel de plataforma.
- **Autoridades Judiciales (Policía Cibernética):** En caso de ataques cibernéticos de origen criminal.

Procedimiento Operativo Estándar

Fase de Detección e Identificación: La detección representa el primer eslabón en la cadena de respuesta. NovaTech emplea un enfoque proactivo para reducir el intervalo táctico entre la brecha y el hallazgo:

- **Fuentes de Vigilancia (El "Cómo" detectamos):**
 - *Monitoreo Automatizado:* Implementación de sistemas de gestión de eventos que analizan logs en tiempo real. Se configuran alertas automáticas para detectar anomalías como fallos de autenticación MFA, conexiones desde geolocalizaciones no autorizadas o picos inusuales de tráfico.
 - *Vigilancia Participativa:* Todo colaborador tiene la responsabilidad de reportar comportamientos anómalos. El reporte humano es vital para detectar ataques de ingeniería social que el software puede ignorar.
- **Inteligencia de Amenazas (El "Qué" buscamos):** Para que la detección sea efectiva, el equipo se apoya en dos niveles de inteligencia:
 - *Indicadores de Compromiso (IoCs):* Búsqueda de huellas digitales de ataques conocidos, como hashes de archivos maliciosos, direcciones IP de servidores de comando y control (C2) y firmas de malware actualizado.
 - *Análisis de TTPs (Tácticas, Técnicas y Procedimientos):* El equipo busca comportamientos sospechosos aunque no haya un virus conocido. Esto

incluye identificar movimientos o intentos de exfiltración de datos desde el CRM hacia nubes públicas no autorizadas.

Fase de Reporte y Notificación: Una vez detectada una posible brecha, el flujo de comunicación debe ser expedito. NovaTech establece los siguientes canales y tiempos de escalamiento, en este caso, el hallazgo debe reportarse a través del portal de gestión de incidentes en un plazo no mayor a 15 minutos tras la detección, el contenido de dicho reporte debe incluir el activo afectado, una breve descripción del síntoma y la hora exacta de detección. Tras la recepción del reporte, el CISO evaluará la información y, de ser necesario, convocará a los miembros pertinentes del equipo de respuesta mediante canales cifrados de emergencia.

Fase de Análisis y Categorización: Una vez recibido el reporte, el CSIRT inicia el proceso de clasificación sistemática para transformar datos crudos en inteligencia operativa. Esta fase se divide en tres procesos críticos:

1. *Matriz de Priorización y Tiempos de Respuesta (SLA):* El CSIRT definirá los tiempos de respuesta basados en la criticidad del activo y el impacto potencial:

Prioridad	Descripción / Ejemplo	Tiempo de Respuesta	Tiempo de Solución
CRÍTICA	Compromiso de Código Fuente o fuga de Datos Sensibles en CRM .	< 30 Minutos	< 4 Horas
ALTA	Caída de servidores en la Nube o infección de malware en estaciones de TI.	< 1 Hora	< 12 Horas
MEDIA	Acceso no autorizado a información "Interna" o pérdida de hardware sin datos sensibles.	< 4 Horas	< 48 Horas
BAJA	Escaneo de puertos sin éxito o intentos de phishing fallidos reportados.	< 24 Horas	< 5 Días Hábiles

- *Tiempo de Respuesta:* Es el plazo máximo para que un analista tome el caso, lo categorice e informe al CISO sobre el inicio de las maniobras de contención.
- *Tiempo de Solución:* Es el objetivo para haber contenido la amenaza y estar en fase de recuperación.

2. *Clasificación por Vectores y Causa Raíz*: Durante el análisis, el CSIRT debe etiquetar el incidente bajo uno de los siguientes vectores:

- *V1 - Ataque Web/Cloud*: Infiltración por vulnerabilidades en aplicaciones.
- *V2 - Ingeniería Social*: Phishing o suplantación de identidad.
- *V3 - Amenaza Interna*: Mal uso de privilegios por parte de empleados o exempleados.
- *V4 - Código Malicioso*: Ransomware o virus.

3. *Análisis Técnico y Correlación de Eventos*: En este punto, los analistas ejecutan las acciones de diagnóstico, con tres las cuales se deberán encargarse de ejecutar, de entre estas tenemos el hacer una correlación de logs de diferentes sistemas para identificar la ruta del atacante. También deberán determinar si el incidente fue producto de una vulnerabilidad no parcheada, un error de configuración o un engaño de ingeniería social. Y el último requisito es que identifiquen todos los *puntos de contacto* del ataque para asegurar que no existan persistencias ocultas o backdoors.

Fase de Contención (Resolución del Dilema Táctico): El objetivo primordial es detener la expansión del incidente y minimizar el daño. El Director del Incidente (CISO), tras consultar con los analistas, deberá elegir una de las siguientes dos estrategias de contención:

- **Estrategia A: Contención de Mitigación Inmediata (Parada en Seco)**: Se aplica cuando el riesgo de pérdida de datos es inminente y superior a la necesidad de investigar al atacante.
 - *Acciones*: Apagado de servidores afectados, desconexión de segmentos de red, bloqueo masivo de cuentas de usuario y revocación de certificados SSL/TLS.
 - *Ventaja*: Detiene la fuga de información al instante.
 - *Desventaja*: Se pierde la evidencia volátil en la memoria RAM y el atacante se da cuenta de que ha sido descubierto, lo que podría llevarlo a borrar sus huellas de forma remota.
- **Estrategia B: Contención Estratégica (Vigilancia y Aislamiento)**: Se aplica cuando se necesita identificar la identidad del atacante o el alcance total de la intrusión antes de actuar.
 - *Acciones*: Movimiento del tráfico sospechoso a un *Honeypot*, aislamiento de instancias en la nube mediante reglas de firewall que permitan el monitoreo, y duplicación de tráfico para análisis en espejo.
 - *Ventaja*: Permite recolectar evidencia forense crítica y entender el *modus operandi* del enemigo sin que este sospeche.

- *Desventaja:* Existe un riesgo residual de que el atacante logre exfiltrar más datos si el aislamiento no es perfecto.

La elección de la estrategia dependerá del activo afectado y la prioridad del incidente: Si el código fuente, se ve afectado, se preferirá la Estrategia A para proteger la privacidad. Si es un incidente menor en una estación de trabajo, se podrá optar por la Estrategia B para fines de investigación.

Fase de Erradicación y Recuperación: Una vez que el incidente ha sido contenido y el perímetro táctico está bajo control, el CSIRT procederá con la restauración definitiva del entorno siguiendo estos protocolos:

1. Erradicación Profunda e Higienización: Con tal de eliminar cualquier posibilidad de que el atacante regrese, se deberán tomar las siguientes medidas:

- *Saneamiento de Identidades:* Rotación obligatoria de todas las contraseñas, tokens de API y llaves SSH que pudieron estar expuestas. En el caso de Git, se deben revocar y reemitir todas las llaves de despliegue.
- *Eliminación de Persistencia:* Identificación y borrado de tareas programadas, servicios nuevos o cuentas de respaldo creadas por el atacante para mantener el acceso.
- *Reconstrucción (Re-imaging):* Siempre que sea posible en la infraestructura Cloud, se optará por destruir las instancias comprometidas y desplegar nuevas desde imágenes limpias o mediante plantillas de Infraestructura como Código, en lugar de intentar limpiar el sistema operativo infectado.

2. Recuperación Gradual y Controlada: La vuelta a la normalidad debe ser escalonada para no saturar los sistemas y detectar si la amenaza persiste.

- *Verificación de Backups:* Antes de la restauración, el Especialista Forense debe validar que los respaldos no estén infectados o cifrados.
- *Restauración por Fases:* Se habilitarán primero los servicios de solo lectura y, tras confirmar estabilidad, se abrirán las funciones de escritura y transaccionales.
- *Monitoreo Intensivo de Post-Recuperación:* Durante las primeras 48-72 horas tras la recuperación, los analistas de seguridad mantendrán un nivel alto de vigilancia sobre el activo afectado para detectar cualquier intento de re-infección.

3. *Endurecimiento (Hardening) de Seguridad*: Se toman las siguientes medidas con tal de que el cierre de la vulnerabilidad sea el definitivo:

- *Sellado de la Causa Raíz*: Aplicación de parches no solo en el sistema afectado, sino en todos los sistemas similares de la red.
- *Ajuste de Reglas de Firewall*: Modificación de los Security Groups de la nube para cerrar puertos que fueron explotados.
- *Sanitización de Datos*: Si el incidente afectó al CRM o a la Base de Datos de Clientes, se realizará una auditoría de integridad para asegurar que el atacante no modificó registros de clientes o cuentas bancarias.

Métricas de Eficacia (Métricas de Tiempo): Para medir qué tan bueno es el CSIRT, se añaden estas métricas al final del procedimiento:

- *MTTD (Mean Time to Detect)*: Tiempo promedio que transcurre desde que el atacante entra hasta que el equipo lo detecta.
- *MTTR (Mean Time to Respond)*: Tiempo promedio desde la detección hasta la contención total del incidente.

Actividad Post-Incidente (Mejora Continua del SGSI)

Tras la declaración formal del cierre del incidente por parte del CISO, el CSIRT entrará en una fase de introspección obligatoria. Esto con el fin de fortalecer la postura de seguridad de NovaTech Solutions a través de los siguientes mecanismos:

Informe Post-Mortem: Se convocará a una reunión de revisión técnica dentro de los primeros 5 días hábiles tras la resolución para documentar:

- *Análisis de Causa Raíz (RCA)*: Determinación técnica de la falla. Se responderá a la pregunta: *¿Cómo ocurrió y por qué no lo detectamos antes?*
- *Cronología de Respuesta*: Comparativa entre los tiempos reales de detección y respuesta frente a los SLA.
- *Evaluación de Herramientas*: Análisis de si las soluciones tecnológicas actuales fueron efectivas o si requieren una recalibración.

Retroalimentación del Ciclo de Vida de Seguridad: El aprendizaje del incidente debe traducirse en cambios tangibles en la organización:

- *Ajuste de Políticas y Controles:* Si el incidente reveló vacíos en las políticas o en el Control de Accesos, estas deberán ser actualizadas y publicadas nuevamente en un plazo no mayor a 15 días.
- *Recalibración del Inventario de Riesgos:* El evento ocurrido debe alimentar futuras evaluaciones de riesgos. Si un riesgo categorizado como bajo causó un impacto alto, se deberán ajustar las variables de probabilidad e impacto en la matriz OCTAVE Allegro.
- *Programa de Concientización:* Los detalles del incidente se utilizarán como casos de estudio en las sesiones de capacitación para evitar la recurrencia por errores humanos similares.

Acciones Disciplinarias y Legales: En estricto cumplimiento con el marco legal mexicano y el reglamento interno de trabajo:

- *Régimen de Sanciones:* Si el análisis forense demuestra que el incidente fue producto de una violación consciente, dolosa o negligente a las políticas de seguridad, el CSIRT turnará el informe técnico a Recursos Humanos para la aplicación de sanciones.
- *Acciones Penales/Civiles:* En caso de robo de propiedad intelectual o sabotaje, el enlace legal iniciará las denuncias correspondientes ante el Ministerio Público o la Policía Cibernética, utilizando la evidencia preservada bajo Cadena de Custodia.